

Static Application Security Testing (SAST) Evidence

Newcoworker LLC · App: New Coworker OAuth (Zoom Marketplace) · Prepared July 2026 · Contact: Brianlane2@gmail.com

1. Tooling

- **GitHub CodeQL** (language pack `javascript-typescript`) is the primary SAST engine, run via GitHub Actions with `security-events: write` so findings land in the repository's Security → Code scanning dashboard.
- **Triggers:** every pull request into `main`, every push to `main`, and a weekly scheduled scan (Mondays 03:22 UTC) so the default branch is re-analyzed against newly released CodeQL queries even without code changes.
- **Complementary controls:** ESLint on every PR, Dependabot vulnerability alerts (tracked to zero, transitive pins via `package.json` overrides), a scheduled dependency audit workflow, and automated AI code review (Cursor Bugbot) on every pull request.

2. Workflow definition (.github/workflows/codeql.yml, verbatim)

```
name: CodeQL

on:
  push:
    branches: [main]
  pull_request:
    branches: [main]
  schedule:
    - cron: "22 3 * * 1"

permissions:
  actions: read
  contents: read
  security-events: write

jobs:
  analyze:
    name: Analyze
    runs-on: ubuntu-latest
    timeout-minutes: 20
    strategy:
      fail-fast: false
      matrix:
        language: ["javascript-typescript"]

    steps:
      - name: Checkout repository
        uses: actions/checkout@v7

      - name: Initialize CodeQL
        uses: github/codeql-action/init@v4
        with:
          languages: ${matrix.language}
          config-file: ../.github/codeql/codeql-config.yml
```

- name: Autobuild
uses: github/codeql-action/autobuild@v4
- name: Perform CodeQL Analysis
uses: github/codeql-action/analyze@v4

3. Finding management

- CodeQL alerts surface on the pull request and in the code-scanning dashboard; the merge policy requires all checks green and all review threads resolved before merge, so findings are addressed pre-merge.
- Dependabot alerts are remediated to zero either by bumping the owning package or pinning the transitive dependency.

DAST note: the application's attack surface is a Next.js web app behind Vercel with signature-verified webhooks; runtime testing is covered by the integration test suites run in CI against real service stacks. Current code-scanning status and run history are available for review on request.